

## MAPEO NORMATIVO DETALLADO: ENCUESTA CIBERSEGURIDAD ORGANIZACIONAL

### Preguntas GQM → Requisitos Regulatorios España/EU

**Versión:** 1.0 | **Fecha:** Enero 2026

**Contexto:** Encuesta Integral Ciberseguridad Organizacional (7 Módulos)

**Normativa Base:** NIS2, ISO 27001, GDPR, COBIT 2019, Plan Nacional Ciberseguridad

### INTRODUCCIÓN: ALINEACIÓN NORMATIVA

Este documento mapea cada pregunta de la encuesta (7 módulos, 51 preguntas totales) contra:

1. Regulaciones Españolas: Plan Nacional Ciberseguridad 2023
2. Regulaciones EU: NIS2 (Directiva 2022/2555), GDPR (Regulación 2016/679)
3. Estándares Internacionales: ISO 27001:2022, COBIT 2019
4. Plazos de Cumplimiento: Críticos, regulatorios
5. Organismos Supervisión: Responsables validación

### MÓDULO 1: GOBERNANZA Y LIDERAZGO EN CIBERSEGURIDAD

#### Pregunta 1.1: Estado actual función ciberseguridad (Nivel 0-5)

| Aspecto                     | Detalle                                                                                                                     |
|-----------------------------|-----------------------------------------------------------------------------------------------------------------------------|
| Pregunta                    | ¿Cuál es el estado actual de la función de ciberseguridad?                                                                  |
| Normativa 1: NIS2           | Artículo 17: "Essential entities deben designar responsabilidad ciberseguridad a nivel ejecutivo; reporta a top management" |
| Normativa 2: ISO 27001:2022 | Clause 5.1: "Liderazgo ejecutivo debe demostrar compromiso; integración governance"                                         |
| Normativa 3: COBIT 2019     | GOV-01: "Gobernanza: estructura organizacional ciberseguridad debe ser visible"                                             |
| Normativa 4: Plan Nacional  | Línea 1.1: "Función ciberseguridad formalizada; asignación recursos; reporting CEO"                                         |
| Plazo Cumplimiento          | NIS2: Agosto 2026 (transposición); ISO: Ongoing; Plan Nacional: 2026                                                        |
| Organismo Supervisión       | CNCS (España), Autoridades Competentes autonómicas                                                                          |
| Mínimo Compliance           | Nivel 3 (Definido): CISO reporta a COO/CEO; presupuesto dedicado; governance formal                                         |
| Penalidad No-Cumplimiento   | NIS2: €50M o 10% turnover; reputación dañada                                                                                |

### Pregunta 1.2: Revisión estrategia ciberseguridad con liderazgo ejecutivo (Frecuencia)

| Aspecto                                     | Detalle                                                              |
|---------------------------------------------|----------------------------------------------------------------------|
| <b>Pregunta</b>                             | ¿Con qué frecuencia se revisa ciberseguridad con leadership?         |
| <b>Normativa 1: NIS2 Art.17</b>             | "Risk assessments at least annually; board oversight required"       |
| <b>Normativa 2: COBIT 2019 GOV-01</b>       | "Governance: executive oversight quarterly minimum"                  |
| <b>Normativa 3: ISO 27001 6.2</b>           | "Top management to review Information Security at planned intervals" |
| <b>Normativa 4: Plan Nacional Línea 1.3</b> | "Revisión estrategia: mínimo trimestral con junta directiva"         |
| <b>Plazo Cumplimiento</b>                   | Inmediato (2026 baseline); continuo                                  |
| <b>Organismo Supervisión</b>                | Internal board; external audit (CNCS)                                |
| <b>Mínimo Compliance</b>                    | Trimestral (Nivel 3); mensuales preferido (Nivel 4)                  |
| <b>Métrica Cumplimiento</b>                 | Board meeting minutes con tema ciberseguridad documentado            |

### Pregunta 1.3: Política ciberseguridad documentada y comunicada

| Aspecto                                     | Detalle                                                                         |
|---------------------------------------------|---------------------------------------------------------------------------------|
| <b>Pregunta</b>                             | ¿Existe política ciberseguridad documentada y comunicada?                       |
| <b>Normativa 1: NIS2 Art.17</b>             | "Organization debe mantener security policies; employee awareness"              |
| <b>Normativa 2: ISO 27001 5.2</b>           | "Security policies shall be established, implemented, communicated"             |
| <b>Normativa 3: GDPR Art.32</b>             | "Data controllers must implement appropriate technical/organizational measures" |
| <b>Normativa 4: Plan Nacional Línea 1.5</b> | "Políticas ciberseguridad: vigentes, comunicadas, cumplidas"                    |
| <b>Plazo Cumplimiento</b>                   | Inmediato                                                                       |
| <b>Organismo Supervisión</b>                | Internal DPO (GDPR); external audit                                             |
| <b>Mínimo Compliance</b>                    | Nivel 3: Policy published; training mandatory; annual review                    |
| <b>Documentación Requerida</b>              | Policy document (v-control), distribution logs, training records                |

#### Pregunta 1.4: Alineación presupuesto ciberseguridad con objetivos negocio

| Aspecto                              | Detalle                                                          |
|--------------------------------------|------------------------------------------------------------------|
| <b>Pregunta</b>                      | ¿Alineación presupuesto cybersecurity con objetivos negocio?     |
| <b>Normativa 1: NIS2 Art.17</b>      | "Adequate resources for cybersecurity must be allocated"         |
| <b>Normativa 2: ISO 27001 6.1</b>    | "Organization to determine resources needed for IS program"      |
| <b>Normativa 3: COBIT 2019 BAI01</b> | "Budget allocation aligned with enterprise priorities"           |
| <b>Plazo Cumplimiento</b>            | Annual budget cycle (Q4 planning para Q1 deployment)             |
| <b>Organismo Supervisión</b>         | CFO, internal audit, external audit                              |
| <b>Mínimo Compliance</b>             | Nivel 3: Budget explicitly mapped to risk/objectives; documented |
| <b>Métrica</b>                       | Budget allocation % tied to top 3 risks                          |

#### Pregunta 1.5: Inversión anual ciberseguridad como % presupuesto IT

| Aspecto                               | Detalle                                                                       |
|---------------------------------------|-------------------------------------------------------------------------------|
| <b>Pregunta</b>                       | ¿Inversión anual ciberseguridad como % presupuesto IT?                        |
| <b>Normativa 1: NIS2</b>              | "Resources adequate; no specific % prescribed but adequacy audited"           |
| <b>Normativa 2: Plan Nacional</b>     | "Benchmark 2026: 5-8% IT budget to cybersecurity es expected"                 |
| <b>Normativa 3: Industry Standard</b> | "Gartner benchmark: 3-5% small-medium; 5-8% enterprise; 8%+ critical sectors" |
| <b>Plazo Cumplimiento</b>             | 2026 baseline establishment                                                   |
| <b>Organismo Supervisión</b>          | CFO; CNCS (NIS2 audits)                                                       |
| <b>Mínimo Compliance</b>              | Nivel 3: 5-8% IT budget; Nivel 4: 8-12%                                       |
| <b>Interpretation</b>                 | <3%: underfunded; 3-5%: adequate small-medium; >8%: strategic priority        |

## MÓDULO 2: GESTIÓN DE VULNERABILIDADES Y PENETRACIÓN

### Pregunta 2.1: Estado madurez programa gestión vulnerabilidades (Nivel 0-5)

| Aspecto                                     | Detalle                                                                                 |
|---------------------------------------------|-----------------------------------------------------------------------------------------|
| <b>Pregunta</b>                             | ¿Estado madurez programa gestión vulnerabilidades?                                      |
| <b>Normativa 1: NIS2 Art.19</b>             | "Operators essential entities must conduct regular vulnerability assessments"           |
| <b>Normativa 2: ISO 27001 A.12.6.1</b>      | "Manage technical vulnerabilities: regular assessments, patch management"               |
| <b>Normativa 3: Plan Nacional Línea 3.4</b> | "Scanning vulnerabilidades: mínimo trimestral; SBOM requerido 2026"                     |
| <b>Plazo Cumplimiento</b>                   | NIS2: Agosto 2026; ISO: Ongoing                                                         |
| <b>Organismo Supervisión</b>                | CNCS, entity security team                                                              |
| <b>Mínimo Compliance</b>                    | Nivel 2: Scanning regular (trimestral); Nivel 3: Continuous + risk-based prioritization |
| <b>Penalidad</b>                            | NIS2 non-compliance: regulatory fine + operational restrictions                         |

### Pregunta 2.2: % vulnerabilidades críticas/altas remediadas dentro SLA

| Aspecto                                | Detalle                                                          |
|----------------------------------------|------------------------------------------------------------------|
| <b>Pregunta</b>                        | ¿% vulnerabilidades críticas remediadas dentro SLA?              |
| <b>Normativa 1: NIS2 Art.17</b>        | "Vulnerability remediation according to severity and risk"       |
| <b>Normativa 2: ISO 27001 A.12.6.2</b> | "Patch management: critical within 15 days; important within 30" |
| <b>Plazo Cumplimiento</b>              | Baseline Q1 2026; continuous improvement through 2026            |
| <b>Organismo Supervisión</b>           | Internal audit; external pen testing validation                  |
| <b>Mínimo Compliance</b>               | Nivel 3: 70-85% on-time; Nivel 4: >90%                           |
| <b>SLA Targets</b>                     | Critical: <15 days; Important: <30 days; Low: <90 days           |

### Pregunta 2.3: Integración scanning vulnerabilidades con threat intelligence

| Aspecto                                | Detalle                                                          |
|----------------------------------------|------------------------------------------------------------------|
| <b>Pregunta</b>                        | ¿Integración scanning con threat intelligence?                   |
| <b>Normativa 1: NIS2 Art.17</b>        | "Threat intelligence integration recommended for prioritization" |
| <b>Normativa 2: ISO 27001 A.16.1.5</b> | "Information security events: monitoring with context"           |
| <b>Plazo Cumplimiento</b>              | 2026-2027 (emerging best practice)                               |
| <b>Organismo Supervisión</b>           | Security operations center (SOC)                                 |
| <b>Mínimo Compliance</b>               | Nivel 3: Threat intel correlated with vulnerabilities            |
| <b>Expected Outcome</b>                | Prioritization accuracy +30%; MTTR reduction                     |

### Pregunta 2.4: Frecuencia pruebas de penetración

| Aspecto                                     | Detalle                                                                     |
|---------------------------------------------|-----------------------------------------------------------------------------|
| <b>Pregunta</b>                             | ¿Frecuencia pruebas penetración?                                            |
| <b>Normativa 1: NIS2 Art.19</b>             | "Security testing including penetration testing required"                   |
| <b>Normativa 2: ISO 27001 A.14.2.5</b>      | "Security testing: assessment of changes before implementation"             |
| <b>Normativa 3: Plan Nacional Línea 3.5</b> | "Pen testing: mínimo anual; bianual para críticos"                          |
| <b>Plazo Cumplimiento</b>                   | Annual minimum; Q2/Q4 2026 baseline                                         |
| <b>Organismo Supervisión</b>                | External assessor (tercero independiente)                                   |
| <b>Mínimo Compliance</b>                    | Nivel 2: Annual; Nivel 3: Bianual for critical; Nivel 4: Quarterly red team |
| <b>Requirement</b>                          | Professional external firm; formal reports with findings                    |

### Pregunta 2.5: Metodología pruebas penetración

| Aspecto                                | Detalle                                                                |
|----------------------------------------|------------------------------------------------------------------------|
| <b>Pregunta</b>                        | ¿Metodología pruebas penetración?                                      |
| <b>Normativa 1: OWASP</b>              | "Testing guide v4.2: framework-based testing required"                 |
| <b>Normativa 2: NIST SP 800-115</b>    | "Technical security testing: defined methodology"                      |
| <b>Normativa 3: ISO 27001 A.14.2.4</b> | "Security testing based on defined procedures"                         |
| <b>Plazo Cumplimiento</b>              | Immediate; methodology selection Q1 2026                               |
| <b>Mínimo Compliance</b>               | Nivel 3: Framework-based (OWASP, NIST); Nivel 4: MITRE ATT&CK modeling |
| <b>Deliverable</b>                     | Test plan, scope, methodology document, findings report                |

#### Pregunta 2.6: Media días MTTR vulnerabilidad crítica hasta remediation

| Aspecto                                     | Detalle                                                                |
|---------------------------------------------|------------------------------------------------------------------------|
| <b>Pregunta</b>                             | ¿Mean Time to Remediate (MTTR) vulnerabilidades críticas?              |
| <b>Normativa 1: NIS2 Art.17</b>             | "Timely remediation proportional to severity"                          |
| <b>Normativa 2: ISO 27001 A.12.6.2</b>      | "Critical patches: 15 day target"                                      |
| <b>Normativa 3: PCI-DSS (if applicable)</b> | "Critical: 30 day maximum per requirement 6.2"                         |
| <b>Plazo Cumplimiento</b>                   | Baseline Q1 2026; target achievement Q4 2026                           |
| <b>Organismo Supervisión</b>                | Vulnerability management team; audit                                   |
| <b>Benchmark 2026</b>                       | MTTR Critical <15 days (target); current industry avg 20-30 days       |
| <b>Penalidad</b>                            | PCI-DSS non-compliance: audit failure; payment processing restrictions |

#### Pregunta 2.7: Retest/validación post-remediation

| Aspecto                                             | Detalle                                                            |
|-----------------------------------------------------|--------------------------------------------------------------------|
| <b>Pregunta</b>                                     | ¿Retest post-remediation?                                          |
| <b>Normativa 1: ISO 27001 A.12.6.2</b>              | "Patching: testing before and after deployment"                    |
| <b>Normativa 2: Change Management Best Practice</b> | "Validation that fix is effective"                                 |
| <b>Plazo Cumplimiento</b>                           | Immediate                                                          |
| <b>Organismo Supervisión</b>                        | QA/Security team                                                   |
| <b>Mínimo Compliance</b>                            | Nivel 3: Manual retest for critical; Nivel 4: Automated validation |
| <b>Expected</b>                                     | 100% retest for critical vulnerabilities                           |

#### Pregunta 2.8: % aplicaciones críticas/datos sensibles evaluadas anualmente

| Aspecto                                | Detalle                                                                   |
|----------------------------------------|---------------------------------------------------------------------------|
| <b>Pregunta</b>                        | ¿% aplicaciones críticas con pruebas penetración anuales?                 |
| <b>Normativa 1: NIS2 Art.19</b>        | "Assessment scope must cover critical assets"                             |
| <b>Normativa 2: ISO 27001 A.14.2.5</b> | "Security testing for significant systems"                                |
| <b>Normativa 3: GDPR Art.32</b>        | "Personal data processing: security testing required"                     |
| <b>Plazo Cumplimiento</b>              | Baseline Q1 2026                                                          |
| <b>Organismo Supervisión</b>           | CISO; external audit                                                      |
| <b>Mínimo Compliance</b>               | Nivel 3: 60%+ critical applications; Nivel 4: 85%+; Nivel 5: 100%         |
| <b>Definition</b>                      | "Critical" = handles financial data, personal data, availability-critical |

### Pregunta 2.9: Scope testing (checkboxes: aplicaciones, infraestructura, APIs, etc.)

| Aspecto                                | Detalle                                                                                   |
|----------------------------------------|-------------------------------------------------------------------------------------------|
| <b>Pregunta</b>                        | ¿Qué elementos incluye scope testing?                                                     |
| <b>Normativa 1: OWASP Top 10</b>       | "Web apps, APIs, infrastructure all in scope"                                             |
| <b>Normativa 2: ISO 27001 A.14.2.4</b> | "All system components subject to testing"                                                |
| <b>Normativa 3: GDPR Art.32</b>        | "All systems processing personal data in scope"                                           |
| <b>Plazo Cumplimiento</b>              | Scope definition Q1 2026                                                                  |
| <b>Organismo Supervisión</b>           | CISO; external assessor validates scope adequacy                                          |
| <b>Mínimo Compliance</b>               | Nivel 3: ≥6 elementos; Nivel 4: ≥8 elementos; Nivel 5: All 8+ elements                    |
| <b>Elements</b>                        | On-premise, Cloud, APIs, IoT, Supply chain, Third-party integrations, CI/CD, Data storage |

## MÓDULO 3: GESTIÓN INFORMACIÓN Y EVENTOS (SIEM)

### Pregunta 3.1: Existencia solución SIEM

| Aspecto                                     | Detalle                                                              |
|---------------------------------------------|----------------------------------------------------------------------|
| <b>Pregunta</b>                             | ¿Existe solución SIEM (o equivalente) desplegada?                    |
| <b>Normativa 1: NIS2 Art.17</b>             | "Security monitoring and detection systems required"                 |
| <b>Normativa 2: ISO 27001 A.16.1.5</b>      | "Monitoring of security events; recording and analysis"              |
| <b>Normativa 3: Plan Nacional Línea 5.1</b> | "SOC capability: SIEM required para entidades críticas"              |
| <b>Plazo Cumplimiento</b>                   | Baseline Q1 2026; deployment Q2 2026                                 |
| <b>Organismo Supervisión</b>                | CNCS; internal audit                                                 |
| <b>Mínimo Compliance</b>                    | Nivel 3: SIEM deployed and operational; Nivel 4: Cloud-scale capable |
| <b>Penalidad</b>                            | Lack of monitoring; regulatory gap; incident detection failure       |

### Pregunta 3.2: Fuentes logs integradas en SIEM (checkboxes)

| Aspecto                                | Detalle                                                                                                                |
|----------------------------------------|------------------------------------------------------------------------------------------------------------------------|
| <b>Pregunta</b>                        | ¿Qué fuentes logs integradas?                                                                                          |
| <b>Normativa 1: NIS2 Art.17</b>        | "Comprehensive monitoring of critical systems"                                                                         |
| <b>Normativa 2: ISO 27001 A.16.1.5</b> | "Monitoring scope: user activities, system events, security events"                                                    |
| <b>Normativa 3: GDPR Art.32</b>        | "Logging for personal data processing systems"                                                                         |
| <b>Plazo Cumplimiento</b>              | Phased; baseline 50% coverage Q1 2026, 100% Q4 2026                                                                    |
| <b>Organismo Supervisión</b>           | CISO; CNCS                                                                                                             |
| <b>Mínimo Compliance</b>               | Nivel 3: ≥6 fuentes; Nivel 4: ≥8; Nivel 5: All 10 sources                                                              |
| <b>Sources</b>                         | Firewalls, Servers, Applications, Databases, Cloud, Endpoints, Identity, Additional security devices, IoT, Custom apps |

### Pregunta 3.3: Capacidad retención logs SIEM

| Aspecto                                | Detalle                                                                   |
|----------------------------------------|---------------------------------------------------------------------------|
| <b>Pregunta</b>                        | ¿Retención logs en SIEM?                                                  |
| <b>Normativa 1: GDPR Art.5</b>         | "Data retention: necessary for purposes; not longer than required"        |
| <b>Normativa 2: NIS2 Art.17</b>        | "Incident investigation: logs must support forensics (typical 1-2 years)" |
| <b>Normativa 3: ISO 27001 A.18.1.3</b> | "Compliance with legal/regulatory requirements; documentation retention"  |
| <b>Normativa 4: Plan Nacional</b>      | "Bench marking: 6-12 meses retención mínima críticos"                     |
| <b>Plazo Cumplimiento</b>              | Baseline Q1 2026                                                          |
| <b>Organismo Supervisión</b>           | DPO (GDPR); compliance officer                                            |
| <b>Mínimo Compliance</b>               | Nivel 3: 6-12 meses; Nivel 4: 1-2 años; Nivel 5: >2 años archived/indexed |
| <b>Cost Factor</b>                     | Retention increases storage cost; balance necessity vs cost               |



#### Pregunta 3.4: Tipos alertas/detecciones implementadas

| Aspecto                                | Detalle                                                                               |
|----------------------------------------|---------------------------------------------------------------------------------------|
| <b>Pregunta</b>                        | ¿Tipos de alertas SIEM implementadas?                                                 |
| <b>Normativa 1: NIS2 Art.17</b>        | "Detection of anomalies and incidents"                                                |
| <b>Normativa 2: ISO 27001 A.16.1.1</b> | "Event classification: relevant security events identified"                           |
| <b>Plazo Cumplimiento</b>              | Baseline Q1 2026; optimization 2026-2027                                              |
| <b>Organismo Supervisión</b>           | SOC; CISO                                                                             |
| <b>Mínimo Compliance</b>               | Nivel 3: Rule-based + behavior correlation; Nivel 4: ML-based; Nivel 5: Predictive AI |
| <b>Expected</b>                        | Detection latency <1 hour (Nivel 3); <30 min (Nivel 4); <5 min (Nivel 5)              |

#### Pregunta 3.5: Volumen eventos procesados diariamente

| Aspecto                                | Detalle                                                    |
|----------------------------------------|------------------------------------------------------------|
| <b>Pregunta</b>                        | ¿Volumen eventos/día procesados SIEM?                      |
| <b>Normativa 1: Capacity Planning</b>  | "Infrastructure must handle peak loads + growth"           |
| <b>Normativa 2: ISO 27001 A.16.1.5</b> | "Systems must have capacity for monitoring purposes"       |
| <b>Plazo Cumplimiento</b>              | Baseline Q1 2026; capacity planning annual                 |
| <b>Organismo Supervisión</b>           | Infrastructure team; CISO                                  |
| <b>Benchmark 2026</b>                  | Essential entities: 10M events/day minimum capacity        |
| <b>Scaling</b>                         | Design for 3x peak load; auto-scaling in cloud deployments |

#### Pregunta 3.6: Tasa false positives estimada

| Aspecto                                    | Detalle                                                   |
|--------------------------------------------|-----------------------------------------------------------|
| <b>Pregunta</b>                            | ¿False positive rate estimated?                           |
| <b>Normativa 1: Operational Excellence</b> | "FP rate impacts analyst efficiency; should be minimized" |
| <b>Normativa 2: Industry Standard</b>      | "Target <15% FP rate (Gartner benchmark)"                 |
| <b>Plazo Cumplimiento</b>                  | Baseline Q1 2026; optimization target Q4 2026             |
| <b>Organismo Supervisión</b>               | SOC metrics; CISO oversight                               |
| <b>Mínimo Compliance</b>                   | Nivel 3: <30% FP rate; Nivel 4: <15%; Nivel 5: <5%        |
| <b>Impact</b>                              | High FP rate causes alert fatigue; real threats missed    |

### Pregunta 3.7: Integración SIEM con SOAR (respuesta automática)

| Aspecto                                | Detalle                                                                                      |
|----------------------------------------|----------------------------------------------------------------------------------------------|
| <b>Pregunta</b>                        | ¿Integración SIEM con SOAR?                                                                  |
| <b>Normativa 1: NIS2 Art.17</b>        | "Incident response: timely response procedures required"                                     |
| <b>Normativa 2: ISO 27001 A.16.1.2</b> | "Response: procedures to respond to incidents"                                               |
| <b>Plazo Cumplimiento</b>              | Baseline Q1 2026; SOAR integration Q2-Q3 2026                                                |
| <b>Organismo Supervisión</b>           | IR team; CISO                                                                                |
| <b>Mínimo Compliance</b>               | Nivel 3: Manual response workflows; Nivel 4: Partial automation; Nivel 5: Full orchestration |
| <b>Expected Benefit</b>                | MTTR reduction: 4+ hours → 30 minutes                                                        |

### Pregunta 3.8: Threat hunts ejecutadas (proactive searching)

| Aspecto                           | Detalle                                                          |
|-----------------------------------|------------------------------------------------------------------|
| <b>Pregunta</b>                   | ¿Threat hunts ejecutadas?                                        |
| <b>Normativa 1: NIST CSF</b>      | "Detect function: advanced threat hunting recommended"           |
| <b>Normativa 2: Plan Nacional</b> | "SOC maturity: proactive hunting component"                      |
| <b>Plazo Cumplimiento</b>         | Pilot Q2 2026; operational Q3 2026                               |
| <b>Organismo Supervisión</b>      | Threat hunting team                                              |
| <b>Mínimo Compliance</b>          | Nivel 3: Monthly hunts; Nivel 4: Weekly; Nivel 5: Continuous     |
| <b>Expected</b>                   | 30-40% of detections from proactive hunting (vs reactive alerts) |

### Pregunta 3.9: Marcos regulatorios cubiertos reportería SIEM (checkboxes)

| Aspecto                                     | Detalle                                                 |
|---------------------------------------------|---------------------------------------------------------|
| <b>Pregunta</b>                             | ¿Frameworks cubiertos por SIEM?                         |
| <b>Normativa 1: GDPR</b>                    | "Breach notification: 72 hours; SIEM supports evidence" |
| <b>Normativa 2: NIS2</b>                    | "Incident reporting: SIEM provides audit trail"         |
| <b>Normativa 3: PCI-DSS (if applicable)</b> | "Logging requirements: SIEM documents compliance"       |
| <b>Plazo Cumplimiento</b>                   | Baseline Q1 2026                                        |
| <b>Organismo Supervisión</b>                | Compliance officer; DPO                                 |
| <b>Requerimiento</b>                        | Reportería automática para cada framework regulatorio   |
| <b>Expected</b>                             | 90%+ compliance documentation available 24/7            |

### Pregunta 3.10: Frecuencia reportería compliance/incident

| Aspecto                                | Detalle                                                                 |
|----------------------------------------|-------------------------------------------------------------------------|
| <b>Pregunta</b>                        | ¿Frecuencia reportes compliance?                                        |
| <b>Normativa 1: NIS2 Art.18</b>        | "Incident reporting within 72 hours; annual summary reporting"          |
| <b>Normativa 2: ISO 27001 A.16.1.3</b> | "Management review: incident reporting at planned intervals"            |
| <b>Plazo Cumplimiento</b>              | 72 hours for reportable incidents; monthly/quarterly management reviews |
| <b>Organismo Supervisión</b>           | Board; external auditors                                                |
| <b>Mínimo Compliance</b>               | Nivel 3: Monthly reports; Nivel 4: Weekly + real-time dashboards        |
| <b>Automation</b>                      | Alerts para threshold triggers (e.g., >5 incidents/week)                |

## MÓDULO 4: GESTIÓN DE ACCESO E IDENTIDAD

### Pregunta 4.1: Estado actual sistema gestión identidades (Nivel 0-5)

| Aspecto                             | Detalle                                                                                    |
|-------------------------------------|--------------------------------------------------------------------------------------------|
| <b>Pregunta</b>                     | ¿Estado sistema gestión identidades?                                                       |
| <b>Normativa 1: NIS2 Art.19</b>     | "Access control and authentication mechanisms"                                             |
| <b>Normativa 2: ISO 27001 A.9.1</b> | "Access control: user registration, entitlement, rights"                                   |
| <b>Normativa 3: GDPR Art.32</b>     | "Pseudonymization and encryption of personal data"                                         |
| <b>Plazo Cumplimiento</b>           | Baseline Q1 2026; strategic planning 2026-2027                                             |
| <b>Organismo Supervisión</b>        | Identity team; CISO                                                                        |
| <b>Mínimo Compliance</b>            | Nivel 3: Centralized directory (AD/LDAP); Nivel 4: Federated identity; Nivel 5: Zero-trust |
| <b>Strategic Goal</b>               | Move from perimeter-based to identity-based security                                       |

#### Pregunta 4.2: Implementación MFA (multi-factor authentication)

| Aspecto                           | Detalle                                                                           |
|-----------------------------------|-----------------------------------------------------------------------------------|
| <b>Pregunta</b>                   | ¿MFA implementada para?                                                           |
| <b>Normativa 1: NIS2 Art.19</b>   | "Multi-factor authentication: for privileged access and remote work"              |
| <b>Normativa 2: GDPR Art.32</b>   | "Authentication for systems processing personal data"                             |
| <b>Normativa 3: Plan Nacional</b> | "MFA: mínimo para acceso administrativo y VPN"                                    |
| <b>Plazo Cumplimiento</b>         | Phase 1 (Admin/VPN): Q1 2026; Phase 2 (All users): Q4 2026                        |
| <b>Organismo Supervisión</b>      | IT security team; compliance                                                      |
| <b>Mínimo Compliance</b>          | Nivel 3: MFA on critical systems (4+ areas); Nivel 4: 6 areas; Nivel 5: Universal |
| <b>Target 2026</b>                | MFA on: VPN, admin access, email, cloud, critical apps, payment systems           |

#### Pregunta 4.3: Programa Privileged Access Management (PAM)

| Aspecto                                       | Detalle                                                                                          |
|-----------------------------------------------|--------------------------------------------------------------------------------------------------|
| <b>Pregunta</b>                               | ¿Existe programa PAM?                                                                            |
| <b>Normativa 1: NIS2 Art.19</b>               | "Privileged access: restricted and monitored"                                                    |
| <b>Normativa 2: ISO 27001 A.9.2.3</b>         | "Management of privileged access rights"                                                         |
| <b>Normativa 3: CIS Controls v8 Control 5</b> | "Account management: privilege least principle"                                                  |
| <b>Plazo Cumplimiento</b>                     | Baseline Q1 2026; implementation Q2-Q3 2026                                                      |
| <b>Organismo Supervisión</b>                  | IT security; audit                                                                               |
| <b>Mínimo Compliance</b>                      | Nivel 3: Password vault + audit; Nivel 4: Session recording + automation; Nivel 5: Zero-standing |
| <b>Expected</b>                               | 100% privileged accounts in PAM by Q4 2026                                                       |

## MÓDULO 5: CAPACITACIÓN Y CONCIENCIA DE SEGURIDAD

### Pregunta 5.1: Tipos capacitación ciberseguridad ofrecida (checkboxes)

| Aspecto                                     | Detalle                                                         |
|---------------------------------------------|-----------------------------------------------------------------|
| <b>Pregunta</b>                             | ¿Tipos capacitación?                                            |
| <b>Normativa 1: NIS2 Art.17</b>             | "Awareness and training on cybersecurity; regular refresher"    |
| <b>Normativa 2: ISO 27001 A.7.2</b>         | "User security awareness and training: competence demonstrated" |
| <b>Normativa 3: GDPR Art.32</b>             | "Personnel: security training"                                  |
| <b>Normativa 4: Plan Nacional Línea 8.1</b> | "Capacitación: obligatoria; cobertura >90%"                     |
| <b>Plazo Cumplimiento</b>                   | Baseline Q1 2026; mandatory by Q2 2026                          |
| <b>Organismo Supervisión</b>                | HR; CISO; compliance                                            |
| <b>Mínimo Compliance</b>                    | Nivel 3: 4+ modalidades; Nivel 4: 6+; Nivel 5: 8+ comprehensive |
| <b>Requerimiento</b>                        | Training matrix by role (developer, admin, user, executive)     |

### Pregunta 5.2: Frecuencia capacitación obligatoria

| Aspecto                             | Detalle                                                                     |
|-------------------------------------|-----------------------------------------------------------------------------|
| <b>Pregunta</b>                     | ¿Frecuencia capacitación?                                                   |
| <b>Normativa 1: NIS2</b>            | "Regular training; at least annual minimum"                                 |
| <b>Normativa 2: ISO 27001 A.7.2</b> | "At planned intervals; refresher training"                                  |
| <b>Normativa 3: Plan Nacional</b>   | "Capacitación mínima: anual; recomendación: semestral"                      |
| <b>Plazo Cumplimiento</b>           | Baseline Q1 2026; compliance Q2 2026                                        |
| <b>Organismo Supervisión</b>        | Training admin; CISO                                                        |
| <b>Mínimo Compliance</b>            | Nivel 2: Annual; Nivel 3: Biannual; Nivel 4: Quarterly; Nivel 5: Continuous |
| <b>Enforcement</b>                  | Mandatory completion tracked; non-completion escalated                      |

### Pregunta 5.3: % empleados completó capacitación

| Aspecto                      | Detalle                                                          |
|------------------------------|------------------------------------------------------------------|
| Pregunta                     | ¿% empleados completó capacitación?                              |
| Normativa 1: NIS2            | "Compliance auditable; records maintained"                       |
| Normativa 2: ISO 27001 A.7.2 | "Competence demonstration: training records"                     |
| Plazo Cumplimiento           | Baseline Q1 2026; 90%+ compliance Q2 2026                        |
| Organismo Supervisión        | HR; LMS admin; CISO                                              |
| Mínimo Compliance            | Nivel 3: 75%+ completion; Nivel 4: 90%+; Nivel 5: 98%+           |
| Tracking                     | Automated LMS reporting; non-completers identified for follow-up |

### Pregunta 5.4: Medición resultados capacitación

| Aspecto                      | Detalle                                                                                  |
|------------------------------|------------------------------------------------------------------------------------------|
| Pregunta                     | ¿Medición efectividad capacitación?                                                      |
| Normativa 1: ISO 27001 A.7.2 | "Competence evaluation: effectiveness measured"                                          |
| Normativa 2: NIST CSF        | "Awareness effectiveness: metrics tracked"                                               |
| Plazo Cumplimiento           | Baseline Q1 2026                                                                         |
| Organismo Supervisión        | Training team; CISO                                                                      |
| Mínimo Compliance            | Nivel 3: Post-training assessment; Nivel 4: Behavioral metrics; Nivel 5: Business impact |
| Metrics                      | Click-rate (phishing), reporting rate, incident-per-employee trend                       |

### Pregunta 5.5: Resultados phishing simulations

| Aspecto                              | Detalle                                                             |
|--------------------------------------|---------------------------------------------------------------------|
| Pregunta                             | ¿Click-rate phishing simulations?                                   |
| Normativa 1: NIST CSF                | "Awareness: phishing simulation recommended"                        |
| Normativa 2: Plan Nacional Línea 8.2 | "Simulaciones phishing: click-rate target <5% by 2026"              |
| Plazo Cumplimiento                   | Baseline Q1 2026; target achievement Q4 2026                        |
| Organismo Supervisión                | Security awareness team                                             |
| Mínimo Compliance                    | Nivel 3: <20% click-rate; Nivel 4: <10%; Nivel 5: <5% + >70% report |
| Improvement                          | Monthly campaigns; trend tracking; department benchmarking          |

#### Pregunta 5.6: Comunicación resultados capacitación

| Aspecto                               | Detalle                                                                          |
|---------------------------------------|----------------------------------------------------------------------------------|
| <b>Pregunta</b>                       | ¿Comunicación resultados a ejecutivos?                                           |
| <b>Normativa 1: ISO 27001 5.1</b>     | "Management commitment: communication of IS performance"                         |
| <b>Normativa 2: COBIT 2019 GOV-03</b> | "Management reporting: transparency to stakeholders"                             |
| <b>Plazo Cumplimiento</b>             | Monthly/quarterly reporting                                                      |
| <b>Organismo Supervisión</b>          | CISO; board                                                                      |
| <b>Mínimo Compliance</b>              | Nivel 3: Quarterly reports; Nivel 4: Monthly dashboards; Nivel 5: Real-time KPIs |
| <b>Content</b>                        | Completion %, click-rate trend, department rankings, ROI impact                  |

#### Pregunta 5.7: Enfoques engagement ciberseguridad (checkboxes)

| Aspecto                                | Detalle                                                      |
|----------------------------------------|--------------------------------------------------------------|
| <b>Pregunta</b>                        | ¿Enfoques engagement?                                        |
| <b>Normativa 1: Behavioral Science</b> | "Sustained awareness: gamification + incentives effective"   |
| <b>Normativa 2: ISO 27001 A.7.4</b>    | "Communication and awareness"                                |
| <b>Plazo Cumplimiento</b>              | Program design Q1 2026; launch Q2 2026                       |
| <b>Organismo Supervisión</b>           | Training team; HR                                            |
| <b>Mínimo Compliance</b>               | Nivel 3: 3+ enfoques; Nivel 4: 5+; Nivel 5: 7+ comprehensive |
| <b>Expected</b>                        | Sustained engagement → improved security outcomes            |

#### Pregunta 5.8: Tópicos capacitación cubiertos (checkboxes)

| Aspecto                             | Detalle                                                                            |
|-------------------------------------|------------------------------------------------------------------------------------|
| <b>Pregunta</b>                     | ¿Tópicos cubiertos?                                                                |
| <b>Normativa 1: OWASP Awareness</b> | "Phishing, BYOD, passwords, data handling"                                         |
| <b>Normativa 2: GDPR Art.32</b>     | "Data protection, privacy, breach handling"                                        |
| <b>Normativa 3: Plan Nacional</b>   | "Minimum topics: phishing, credentials, incident reporting"                        |
| <b>Plazo Cumplimiento</b>           | Q1 2026 baseline                                                                   |
| <b>Organismo Supervisión</b>        | Training design team                                                               |
| <b>Mínimo Compliance</b>            | Nivel 3: 5-6 tópicos; Nivel 4: 7-8; Nivel 5: All 9                                 |
| <b>Annual Update</b>                | Curriculum reviewed annually; emerging topics added (e.g., AI phishing, deepfakes) |

## RESUMEN: TABLA CONSOLIDADA

| Módulo                     | Pregunta                       | Normativa Primaria        | Plazo Clave | Organismo | Score Mín       |
|----------------------------|--------------------------------|---------------------------|-------------|-----------|-----------------|
| <b>1. Gobernanza</b>       | 1.1 - Estado CISO              | NIS2 Art.17, ISO 5.1      | Agosto 2026 | CNCS      | Nivel 3         |
|                            | 1.2 - Revisión estrategia      | NIS2 Art.17               | Trimestral  | Board     | Trimestral      |
|                            | 1.3 - Política documented      | NIS2 Art.17, ISO 5.2      | Inmediato   | Internal  | Nivel 3         |
|                            | 1.4 - Presupuesto alineado     | NIS2 Art.17               | Annual      | CFO       | Nivel 3         |
|                            | 1.5 - % IT budget              | Plan Nacional             | 2026        | CNCS      | 5-8%            |
| <b>2. Vulnerabilidades</b> | 2.1 - VM maturity              | NIS2 Art.19, ISO A.12.6.1 | Agosto 2026 | CISO      | Nivel 2         |
|                            | 2.2 - % SLA compliance         | NIS2 Art.17, ISO A.12.6.2 | Ongoing     | Audit     | 70%+            |
|                            | 2.3 - Threat intel integration | NIS2 Art.17               | 2026-2027   | SOC       | Nivel 3         |
|                            | 2.4 - Pen test frequency       | NIS2 Art.19, ISO A.14.2.5 | Q2/Q4 2026  | Assessor  | Annual min      |
|                            | 2.5 - PT methodology           | OWASP, NIST SP 800-115    | Q1 2026     | CISO      | Framework-based |
|                            | 2.6 - MTTR critical            | NIS2 Art.17, ISO A.12.6.2 | Q4 2026     | VM team   | <15 days        |
|                            | 2.7 - Retest validation        | ISO A.12.6.2              | Ongoing     | QA        | 100% critical   |
|                            | 2.8 - % apps tested            | NIS2 Art.19, ISO A.14.2.5 | Q1 2026     | CISO      | 60%+            |
|                            | 2.9 - Test scope               | OWASP, ISO A.14.2.4       | Q1 2026     | CISO      | 6+ elements     |
| <b>3. SIEM</b>             | 3.1 - SIEM deployed            | NIS2 Art.17, ISO A.16.1.5 | Q2 2026     | CISO      | Deployed        |
|                            | 3.2 - Log sources              | NIS2 Art.17, GDPR Art.32  | Q4 2026     | CISO      | 6+ sources      |
|                            | 3.3 - Log retention            | GDPR Art.5, NIS2 Art.17   | Q1 2026     | DPO       | 6-12 months     |
|                            | 3.4 - Alert types              | NIS2 Art.17, ISO A.16.1.1 | Q1 2026     | SOC       | ML-based        |
|                            | 3.5 - Event volume             | Capacity planning         | Annual      | IT        | 10M/day min     |



|                        |                              |                            |             |             |                |
|------------------------|------------------------------|----------------------------|-------------|-------------|----------------|
|                        | 3.6 - False positive rate    | Industry best practice     | Q4 2026     | SOC         | <15%           |
|                        | 3.7 - SIEM-SOAR integration  | NIS2 Art.17, ISO A.16.1.2  | Q3 2026     | IR          | Nivel 4        |
|                        | 3.8 - Threat hunts           | NIST CSF                   | Q3 2026     | Threat Hunt | Monthly+       |
|                        | 3.9 - Frameworks covered     | GDPR, NIS2, PCI-DSS        | Q1 2026     | Compliance  | All applicable |
|                        | 3.10 - Reporting frequency   | NIS2 Art.18, ISO A.16.1.3  | 72h/monthly | Board       | Real-time      |
| <b>4. Acceso</b>       | 4.1 - Gestión identidades    | NIS2 Art.19, ISO A.9.1     | 2026-2027   | Identity    | Nivel 3+       |
|                        | 4.2 - MFA implementation     | NIS2 Art.19, Plan Nacional | Q4 2026     | IT Sec      | 6+ areas       |
|                        | 4.3 - PAM program            | NIS2 Art.19, ISO A.9.2.3   | Q3 2026     | IT Sec      | Nivel 3+       |
| <b>5. Capacitación</b> | 5.1 - Tipos training         | NIS2 Art.17, ISO A.7.2     | Q2 2026     | HR/CISO     | 4+ tipos       |
|                        | 5.2 - Frequency              | NIS2, ISO A.7.2            | Q2 2026     | Training    | Biannual+      |
|                        | 5.3 - Completion %           | NIS2, ISO A.7.2            | Q2 2026     | LMS         | 90%+           |
|                        | 5.4 - Effectiveness measured | ISO A.7.2, NIST            | Q1 2026     | Training    | Assessed       |
|                        | 5.5 - Phishing click-rate    | NIST CSF, Plan Nacional    | Q4 2026     | Awareness   | <10%           |
|                        | 5.6 - Results communicated   | ISO 5.1, COBIT 2019        | Monthly     | CISO        | Real-time      |
|                        | 5.7 - Engagement approaches  | Behavioral science         | Q2 2026     | Training    | 5+ approaches  |
|                        | 5.8 - Topics covered         | OWASP, GDPR, Plan Nac      | Q1 2026     | Training    | 7-8 topics     |

**FIN DE MAPEO NORMATIVO**